

API Security with Tyk: Request Quotas

Learn how request quotas in Tyk limit the total number of API calls a user or client can make over a defined time period (e.g., daily, monthly). This helps enforce usage plans, prevent abuse, and manage resource consumption fairly.

Quotas

A quota provides a limit of the number of requests an API client can make:

- Similar to a rate limit, but over a longer term

Defined as a number of requests over a specific period of time, based on a selection of predefined durations:

- 1 hour, 6 hours, 12 hours, 24 hours, 1 week, 1 month, 6 months, 12 months

Once the quota is depleted, requests will be blocked

Quota Configuration

Quotas are configured on a Key or Policy via these properties:

- `quota_max` is the amount of quota initially provided
- `quota_renewal_rate` is used to calculate the epoch after which the quota can be reset to the maximum value
- Policies can define separate quotas for each API they grant access to

A Key will track the quota state via these properties:

- `quota_remaining` is the amount of quota remaining
- `quota_renews` is the epoch after which the quota can be renewed

Quota Enforcement

Quota calculation is based on the amount of quota remaining:

- If the quota remaining is zero, the request is blocked
- Otherwise, the remaining quota is reduced by 1

API clients which have no quota remaining receive this response:

- HTTP status code: 403 Forbidden
- Body: `quota exceeded`

A Tyk 'quota exceeded' system event is triggered

If a quota renewal value is set to -1 then no quota is enforced

Quota Renewal

Quotas are renewed on the first request after the quota renewal epoch:

- The quota remaining is reset to the original quota value
- The new quota renewal epoch is calculated as the current time of the request plus the quota period

As the new epoch is calculated using the time of the request which triggers the renewal, the quota 'window' will move forward at each renewal

Quota Headers

For requests subject to a quota, the Gateway will return headers in the response which provide the current status of the quota:

- X-Ratelimit-Limit: The original quota amount
- X-Ratelimit-Remaining: The current quota remaining
- X-Ratelimit-Reset: The epoch from which the quota can renew

These headers are not returned when a request is blocked due to exceeding the quota

Quota Example

